技 术 文 档

河海大学校园网自动登录工具

ePortal 认证协议分析与工程实现

项目地址	github.com/Icymercury/HHU-CampusAutoLogin
认证系统	锐捷 ePortal（eportal.hhu.edu.cn）
技术栈	Python 3 · tkinter · Windows Task Scheduler
文档日期	2026 年 11 月

目录

一　项目概述

二　技术选型与架构

三　认证协议逆向分析

四　核心实现要点

五　开机自启与权限模型

六　疑难问题记录

七　打包与分发策略

八　安全设计

九　局限与后续方向

附录　接口参数速查

一、项目概述

1.1 需求背景

河海大学校园网采用锐捷 ePortal 网页认证。每次开机后需要手动打开浏览器、进入认证门户、点击登录，才能恢复网络访问。对于需要开机即联网的场景（远程桌面、后台下载、无人值守），这个手动步骤成为阻碍。

1.2 设计目标

- **开机自动完成认证**，且不依赖用户登录桌面（不输 PIN 也执行）
- **零第三方依赖**，不依赖浏览器、驱动或运行时库
- **图形界面配置**，面向非技术用户，输入一次账号密码即可
- **可分发**，能打包成单个文件夹供同学下载使用

1.3 关键结论

> 经实测验证：河海大学 ePortal 的密码**以明文提交**，登录页默认 `passwordEncrypt=false` 。因此无需实现任何加密算法，也不必读取浏览器 Cookie 中的密文——这大幅简化了整个方案。

二、技术选型与架构

2.1 三条路线的取舍

方案	可靠性	维护成本	结论
Selenium / Playwright 驱动浏览器	中	高，浏览器升级或页面改版即失效	否决
直接构造 HTTP 请求	高	低，接口稳定则无需维护	**采用**
第三方客户端	高	低	否决，存在捆绑风险

浏览器自动化的根本缺陷在于：它把流程押在页面 DOM 结构上。登录页改一次样式、换一个元素 ID，整个脚本就会失效。而直接调用接口，只要认证协议不变，页面怎么改都不影响。

2.2 模块划分

```
auto_login.py
├── DPAPI 加解密        CryptProtectData / CryptUnprotectData（机器级）
├── 配置管理            config.json + state.json
├── 网络层              状态探测 / 会话参数提取 / 登录提交
├── 调度层              Windows 任务计划（schtasks）
├── 界面层              tkinter 主窗口 + 设置窗口
└── CLI 入口            --run / --install / --toggle / --status
```

2.3 运行流程

```
开机（或登录桌面）
   ↓ 45 秒延迟，等网卡与 DHCP 就绪
探测门户是否可达（TCP 80）
   ↓ 不可达 → 判定不在校园网 → 静默退出
探测当前是否已在线
   ↓ 已在线 → 退出
抓取本次会话的 queryString
   ↓
提交认证请求
   ↓ 失败则重试 3 次，间隔 15 秒
复验在线状态 → 写日志
```

三、认证协议逆向分析

3.1 认证流程的三段式

锐捷 ePortal 的认证并非简单的表单提交，而是分三段：

1. **网关拦截**：未认证时访问任意 HTTP 站点，请求被网关截获
2. **下发会话参数**：网关返回一个跳转页面，携带本次会话的 `wlanuserip`、`mac`、`nasip` 等参数
3. **提交认证**：向 `InterFace.do?method=login` 提交账号、密码和上述会话参数

> **关键陷阱：未认证时网关返回的是 200，不是 302。**
> 跳转由页面内的 JavaScript 完成：
>
> ```
> <script>top.self.location.href='http://eportal.hhu.edu.cn/eportal/index.jsp?wlanuserip
> =...'</script>
> ```
>
> 如果只判断 HTTP 状态码，会把未认证误判为已认证，导致整个登录流程被跳过。正确做法是检查响应正文中是否包含 `eportal` 字样。

3.2 会话参数必须动态获取

`queryString` 中包含每次连接都不同的值：

wlanuserip	本机内网 IP，由 DHCP 分配，加密后传输
mac	网卡 MAC。注意 Windows 默认开启「随机硬件地址」，每次连接可能变化
nasip / nasid	接入设备的标识
port / nasportid	接入端口

因此脚本不能硬编码这些参数，必须每次从跳转页面中实时提取。

3.3 密码加密的真实情况

登录页的隐藏字段给出了答案：

```
<input id="passwordEncrypt" name="passwordEncrypt" value="false" type="hidden">
<input id="publicKeyExponent" name="publicKeyExponent" value="" type="hidden">
<input id="publicKeyModulus"  name="publicKeyModulus"  value="" type="hidden">
```

默认值为 `false`，且 RSA 公钥的两个字段为空——说明**学校未启用密码加密**，密码以明文提交。

> 那为什么在浏览器里抓包会看到 `passwordEncrypt=true` 和一大串十六进制密文？
> 那是浏览器「记住密码」功能产生的：它把加密后的密文回填到表单，JS 检测到字段已有值，就把标志位置为 `true` 直接提交。全新输入密码时走的是明文路径。

3.4 运营商参数的双重身份

这是本项目最隐蔽的一个坑。登录页的下拉框选项，**显示名和提交值不是一回事**：

界面显示名	实际提交值（serviceName）
校园网(Campus NET)	校园外网服务(out-campus NET)
中国移动(CMCC NET)	中国移动(CMCC NET)
中国电信(CTCC NET)	中国电信(常州)
中国联通(CUCC NET)	中国联通(常州)

只有中国移动两者恰好同名，其余三个全都不同。如果直接提交显示名，除移动外的账号一律报错「用户不允许使用本服务」。

这些信息可通过 `InterFace.do?method=getServices` 接口动态获取，返回的 `services` 数组中同时包含 `serviceName` 与 `serviceShowName` 两个字段。

3.5 参数编码规则

`service` 与 `queryString` 在提交时需要**两次 URL 编码**：

```
中国移动(CMCC NET)
  → %E4%B8%AD%E5%9B%BD%E7%A7%BB%E5%8A%A8(CMCC%20NET)      第一次
  → %25E4%25B8%25AD...(CMCC%2520NET)                      第二次
```

使用 Python 的 `requests` 传字典会自动编码一次，叠加后变成三次，反而失败。必须手工拼接请求体。括号是 JS `encodeURIComponent` 的保留字符，不参与编码。

四、核心实现要点

4.1 在线状态判定

```
def probe(cfg):
    for url in ("http://www.baidu.com", "http://connect.rom.miui.com/generate_204"):
        code, hdrs, body = fetch(url, cfg, timeout=8)
        text = body.decode("utf-8", "ignore")
        blob = (hdrs.get("Location", "") + " " + text[:4000]).lower()
        if "eportal" in blob:
            return "offline"      # 被劫持到门户页
        if code == 200 or code in (301, 302, 303, 307, 308):
            return "online"
    return "unknown"
```

判据是**响应内容是否包含门户地址**，而非状态码。这是 3.1 节那个陷阱的直接应对。

4.2 提交认证

```
payload = ("userId=%s&password=%s&service=%s&queryString=%s"
           "&operatorPwd=&operatorUserId=&validcode=&passwordEncrypt=false"
           % (euc(uid), euc(pwd), euc(euc(service_name)), euc(euc(query_raw))))

fetch(portal + "/eportal/InterFace.do?method=login",
      data=payload.encode("utf-8"), referer=idx_url)
```

返回为 JSON：成功时 `{"result":"success","userIndex":"..."}`，失败时 `result` 为 `fail` 并带中文错误描述。

4.3 错误的语义映射

服务端返回	实际含义
用户不允许使用本服务	service 参数与账号绑定的套餐不符，或填了显示名而非提交值
运营商用户认证失败 [运营商绑定账号错误]	选了运营商服务，但该账号未绑定此运营商
密码错误 / 认证失败	账号或密码有误
result: success 但复验仍离线	认证成功但 IP 绑定未生效，通常需要短暂等待

五、开机自启与权限模型

5.1 为什么必须用「启动时」触发器

Windows 任务计划有两类触发器：

- **计算机启动时（BootTrigger）**——在用户登录界面出现**之前**触发，以 SYSTEM 身份运行，无需任何人输入 PIN
- **用户登录时（LogonTrigger）**——必须先登录桌面

项目同时配置了两个触发器：BootTrigger 负责真正的开机场景，LogonTrigger 覆盖休眠唤醒等启动事件不触发的情况。

> **必须勾选「不管用户是否登录都要运行」。**默认创建的任务是「仅在用户登录时运行」，不修改此项，任务会停在等待状态，什么都不执行。

5.2 快速启动的陷阱

Windows 10/11 默认开启「启用快速启动」。这个功能让「关机」变成一种休眠——系统把内核状态写入 `hiberfil.sys`，下次开机直接恢复，**并没有执行完整启动流程。**

后果是 BootTrigger **可能根本不触发。**表现极具迷惑性：手动测试一切正常，实际使用却时灵时不灵。

解决：控制面板 → 电源选项 → 选择电源按钮的功能 → 更改当前不可用的设置 → 取消勾选「启用快速启动」。

5.3 权限模型

操作	是否需要管理员	实现方式
查询任务状态	否	schtasks /query，失败时降级为普通查询
创建 / 删除 / 启停任务	**是**	ShellExecuteW + runas，触发 UAC
日常自动登录	否	任务本身以 SYSTEM 运行

六、疑难问题记录

现象	根因	修法
未认证时被判定为已在线	网关返回 200 + JS 跳转，只判断状态码会误判	改为检查响应正文是否含 eportal
非移动账号登录报「用户不允许使用本服务」	提交的是下拉框显示名，而非 serviceName	建立显示名到提交值的映射，并动态拉取服务列表
程序显示「已启用」，但点停用无反应	不带 /v 查询时字段名是「模式」而非「状态」，解析永远落空	同时匹配「状态」与「模式」，兼容英文 Status/Mode
点安装自启提示「拒绝服务」	GUI 直接调用 schtasks，未提权	改为 ShellExecuteW 以 runas 方式启动
提权操作始终无效果	-Verb RunAs 与 -WindowStyle Hidden 在参数集上冲突，命令解析失败且错误被吞	绕开命令行，直接调用 Windows API
普通用户打开程序显示「未安装」	查询 SYSTEM 任务的 /v 详情需要权限，返回非零码	查询失败时降级为普通查询，拿不到运行命令则跳过路径比对
移动文件夹后开机不自启	任务计划只能存绝对路径，移动后指向不存在的文件	记录安装时路径，启动时比对并提示重新安装
把 config.json 拷到别的电脑后静默失败	DPAPI 为机器级加密，换机器无法解密	解密失败时在界面明确提示，而非静默退出

七、打包与分发策略

7.1 单文件 vs 文件夹

对比项	onefile（单文件）	onedir（文件夹）
体积	约 12 MB	exe 2 MB + 依赖目录
启动	先自解压到临时目录，慢 2–4 秒	直接运行
杀软观感	自解压行为与木马高度相似，**误报率高**	正常程序目录，误报率低
结论	—	**采用**

使用 `--contents-directory runtime` 可将依赖目录重命名，最终结构为：

```
CampusAutoLogin/
├── CampusAutoLogin.exe
├── runtime/                （依赖，不可单独移动）
├── 使用说明.txt
└── 安装开机自启.bat
```

7.2 SmartScreen 与误报

未签名的 exe 必然触发 SmartScreen「未知发布者」警告。这是签名问题，与打包方式无关，个人开发者难以规避（代码签名证书年费数千元）。

> **测试陷阱：**本地压缩的 zip 没有「网络来源标记」（Zone.Identifier），解压出的 exe 不会触发 SmartScreen；而用户从 GitHub 下载的 zip 带有该标记，exe 会继承它并触发拦截。要复现真实场景，需给 exe 手动写入：
>
> ```
> Add-Content -Path app.exe -Stream Zone.Identifier -Value "[ZoneTransfer]`r`nZoneId=3"
> ```

本项目在 VirusTotal 上的检出率为 60+ 引擎中的 1 个，属典型的启发式误报。

八、安全设计

8.1 密码存储

使用 Windows DPAPI 加密，关键在于选择**机器级**而非用户级：

```
CryptProtectData(&in, NULL, NULL, NULL, NULL,
                 CRYPTPROTECT_LOCAL_MACHINE, &out);
```

> 若使用用户级加密（标志传 0），开机时以 SYSTEM 身份运行的任务**将无法解密**，自动登录必然失败。机器级虽降低了隔离强度，但同机任何身份均可解密，是本场景的唯一可行选择。

加密结果存入 `config.json`。该文件被拷到其他电脑后无法解密，等同乱码。

8.2 敏感信息隔离

- 源码中**不含**任何账号、密码、IP 或用户名
- 开发期的调试脚本与真实配置隔离在 `_private/`，并写入 `.gitignore`
- 日志中不记录密码，仅记录提交的服务名与返回结果

8.3 内存中的明文

提交认证时密码必须以明文还原，这是协议要求。程序仅在内存中短暂持有，不落盘、不写日志。这一环节无法进一步加固。

九、局限与后续方向

9.1 已知局限

- **仅适配河海大学。**其他学校若使用不同认证系统或启用了 RSA 加密，需重新分析协议。
- **不提供定时保活。**校园网存在 1–2 天强制下线的情况，当前仅覆盖开机与登录两个时机。
- **任务路径不可相对化。**Windows 任务计划只接受绝对路径，移动文件夹后需重新安装。
- **非管理员读不到任务运行命令**，路径比对依赖本地记录的安装路径，属间接判断。

9.2 可选演进

1. **定时心跳守卫**：每小时探测一次，掉线自动重连，可解决长时间挂机断网。
2. **多配置切换**：支持保存多组账号/服务，适配多校区或多环境。
3. **服务列表本地缓存**：离线时也能展示完整运营商选项。
4. **自动更新检查**：启动时比对 GitHub Releases 版本号。

附录、接口参数速查

A.1 认证接口

URL	`POST /eportal/InterFace.do?method=login`
Content-Type	application/x-www-form-urlencoded; charset=UTF-8
Referer	门户 index.jsp 的完整地址

参数	必填	说明
userId	是	学号
password	是	明文密码（passwordEncrypt=false 时）
service	是	运营商提交值，需双重 URL 编码
queryString	是	会话参数串，需双重 URL 编码
passwordEncrypt	是	固定 `false`
operatorPwd / operatorUserId / validcode	否	留空

A.2 服务列表接口

URL	`GET /eportal/InterFace.do?method=getServices`
用途	获取可用运营商列表，无需登录
返回	JSON，`services` 数组含 serviceName 与 serviceShowName

A.3 注销与状态查询

注销	`POST /eportal/InterFace.do?method=logout`，body 传 userIndex
在线信息	`GET /eportal/InterFace.do?method=getOnlineUserInfo`

A.4 userIndex 结构

形如 `3234316562...` 的十六进制串，两位一组转 ASCII 后为：

```
{32位十六进制标识}_{本机内网IP}_{学号}
```

该值由服务端会话生成，每次登录不同，不可自行构造。

本文档由项目开发过程整理而成，可与 `README.md` 配合阅读。README 面向使用者，本文档面向开发者与后续维护者。